

A common way of providing access to the key is M-of-N control. Here, N number of admins are permitted to access the key and M number should be present to provide the access.

The key also needs to be backed up. If lost, access to the encrypted information would become a challenge. However, key backup increases the complexity of making it secure.

Key escrow

In key escrow, the private keys associated with public keys are archived and secured by the third party. Complete control is given to the third party to perform actions on behalf of the users. Organisations use it as it enables full control on the information at rest or in transit. If misused, it could cause harm.

Certificate revocation lists or CRLs

Certificates can be revoked or suspended for various reasons such as if they are compromised or no longer needed. Suspended keys are given a code called 'certificate hold'. CAs maintain a list of all these suspended, revoked certificates to avoid their usage.

CRL is a mechanism for distributing the certificate revocation information. This needs to be updated constantly with the latest revoked details, usually once in every two weeks.

Online certificate status protocol or OCSP

OCSP servers are an alternative to CRL, where instead of validating the whole set, only the status of the requested certificate is communicated. Most OCSP servers can query the certificate database directly and obtain the real-time status of a certificate.

Other OCSP servers depend on the CRLs and are limited by the CRL publishing interval, which at times does not hold up-to-date information.

OpenSSL

Using the *openssl* command we can manage CA services such as:

- Create the public and private key
- Configure root CA
- Configure certificate to host
- Create CSRs
- Manage keys and certificates

OCSP stapling

One issue with the OCSP server is that it requires a heavy load of the request responses. Also, it can record the requests from the clients leading to privacy issues.

OCSP stapling resolves these by using the SSL/TLS server and periodically obtaining a time stamped OCSP response from the CA.

The OCSP stapling process involves the following steps:

- A TLS-encrypted web server presents its certificate to the CA to check the validity.
- The CA responds with the certificate status, including a digitally signed time stamp.
- The web server staples the CA's signed time stamp to the certificate when a client web browser connects.
- When the client makes an OCSP request, the server returns a time stamped response rather than making the client talk to the OCSP server itself.
- The client web browser verifies the signed time stamp.

The privacy issue is reduced here, as the browser does not need to contact the third party or even the internal CA and reveal the browsing history.

Certificate pinning

There is a possibility of using a compromised certificate, which could lead to man in the middle or MITM attacks. Certificate pinning extends beyond certificate validations to avoid MITM attacks.

Pinning refers to the techniques used to make sure the client inspects the proper certificate. This can be achieved by either embedding the certificate along with the data so that we can decrypt and then validate the public key or by using more than one public key.

A similar (though now deprecated) variation, known as HTTP Public Key Pinning (HPKP), uses public key pins, which are essentially hashed values of the public key communicated to the browser client from the server in the HTTP header. After obtaining the server certificate, the client verifies the public key against the hash of the public key.

The challenges

PKI does have a few issues that need to be dealt with:

- It increases the operational cost of maintaining infrastructure.
- Synchronisation between the server and client is critical, in case either one rejects the certificate.
- There is the overhead of maintaining the keys securely and disposing them carefully only after decryption.
- Constant effort is needed with respect to validation if the keys are compromised, if the algorithm needs to be changed, or if the CRL list is too long.

I do hope this article has got you acquainted with the importance of PKI. Further reading is suggested for getting more in-depth knowledge on the subject. **END** 🐼

By: Thangaselvi Arichandrapandian

The author works in a leading bank as AVP. She is a perennial learner and loves the quote: "The more I learn, the more I realise how much I don't know." -Albert Einstein